LAB ASSIGNMENT REPORT

Course: Web Security & Penetration Testing | Assignment: DAY57-SEARCH-TECHNIQUES

DAY 57

Jiwosh Shrestha

Q1–Q3 — OPERATORS, QUERY DESIGN, LIMITATIONS (10 MARKS)

Q1 — Operators [4]

site: restricts results to a domain — site:example.com password reset. **filetype:** limits to a file extension — filetype:pdf "security policy". **intitle:** requires a term in the page title — intitle:"index of" backups. **inurl:** requires a term in the URL path — inurl:admin login. **Quotes** force an exact phrase — "all rights reserved" site:example.org. **Minus** excludes a term — apple -fruit (results about the company, not the food). **OR** broadens to either term — (login OR signin) site:example.com. Operators are combined to narrow noise while keeping the query aligned to the intelligence question.

Q2 — Query design [3]

Turning a question into a query: (1) Extract key entities and attributes from the question (e.g. organisation name, product, document type). **(2) Choose primary terms and controlled synonyms. (3) Add constraints —** site/domain, filetype, date range, language — so results stay in scope. **(4) Exclude known noise with minus terms. (5) Run, sample results, then refine** (narrow or broaden) based on precision and recall. **Example:** Question — "Does Example Corp publish a public security whitepaper?" → query: "Example Corp" ("security whitepaper" OR "security overview") filetype:pdf. Constraints keep the search inside public documentation and avoid unrelated marketing pages.

Q3 — Limitations [3]

Personalisation: search engines may rank results based on location, history or account — two analysts can see different top hits. Mitigate with private/incognito mode, consistent region settings, and cross-engine checks. **Index coverage:** not every public page is indexed; new, blocked or low-link pages may be missing. **Absence is not proof:** failing to find a document does not prove it never existed or was never public — only that it was not retrieved under the queries and engines used within the time box. Record what was searched and the limits so the gap is explicit.

Q4–Q6 — ARCHIVES, CROSS-ENGINE COMPARISON, FALSE POSITIVES (8 MARKS)

Q4 — Archives [3]

Archive links (e.g. Internet Archive / Wayback Machine, archive.today) matter because live pages change or disappear. An archived capture preserves a specific version at a known timestamp, supporting later review and dispute. **Recording practice:** store the archive URL, the original URL, the capture timestamp (UTC), and a short note of what was relevant. Where possible, keep a local hash or screenshot of the archived view. Cite the archive link in the evidence log so a reader can reopen the same version.

Q5 — Cross-engine [3]

Comparison method: run the same core query (and one refined variant) on at least two engines; log the top-N results, notable unique hits, and ranking differences. **What differences mean:** engines use different indexes, ranking signals and spam filters. A hit on only one engine may still be valid — treat it as a lead and verify on the source page. Systematic absence across engines strengthens (but does not prove) a negative finding. Cross-engine work reduces single-vendor bias and personalisation effects.

Q6 — False positives [2]

Example: a query for "Example Corp" confidentiality agreement returns a template from an unrelated law-firm blog that happens to use the phrase in a sample clause. **Verification step:** open the source, check the publisher, date and full context; confirm whether the document is actually issued by or about the subject organisation. If not, log it as a false positive and exclude it from judgements. Never promote a hit to evidence without reading the underlying page.

Q7 — ETHICS (2 MARKS)

Q7 — Ethics [2]

If a search surfaces exposed credentials (API keys, passwords, private keys): (1) Do not use them — access with found credentials is unauthorised. **(2) Do not share or publish the secret values in reports;** redact to a non-recoverable form (e.g. first/last characters only or a hash). **(3) Record the location** (URL, archive link, timestamp) as evidence of exposure, not as a usable secret. **(4) Follow organisational responsible-disclosure or incident process** if the exposure affects a real system in scope — notify the owner through proper channels. **(5) For training exercises using public documentation only,** stop at documentation of the finding pattern; do not pivot into live systems.

Key takeaways

- Operators refine scope; absence of hits is not proof of absence.
- Archive and cross-engine checks improve durability and reduce single-source bias.
- Exposed credentials: document exposure, redact values, never use — disclose responsibly.